

次の問1は必須問題です。必ず解答してください。

問1 企業グループのセキュリティ対策に関する次の記述を読んで、設問に

Z社は总部，L社等は子公司。各公司通过VPN使用总部的共用系统，同时也有自己的内部系统。系统由外包开发，**共用系统**由总部管理，各公司的电脑、服务器和**内部系统**由各自管理。

Z社は、産業機械を製造する企業で、L社をはじめとする複数の子会社グループを形成している。Z社グループでは、Webベースの業務システム用されており、グループ各社が共通で利用できる共通業務システムと、各社から利用できる個別業務システムの2種類がある。共通業務システムはZ社ネットワーク内のセグメントG中に構築され、グループ各社の拠点間を接続するインターネットVPN経由でアクセスされる。個別業務システムは各社が個別に構築する。インターネットVPN経由も含めて社外からはアクセスできない。

業務システムは全てZ社グループ外に委託して開発したものであり、業務システムの運用管理はZ社の情報システム部が、個別業務システムの運用管理はL社の情報システム部が、それぞれ行っている。業務システムが稼働しているZ社各社の業務用PCについては、各社の情報システム部が設定及び運用している。Z社グループのネットワーク構成（抜粋）を図1に示す。

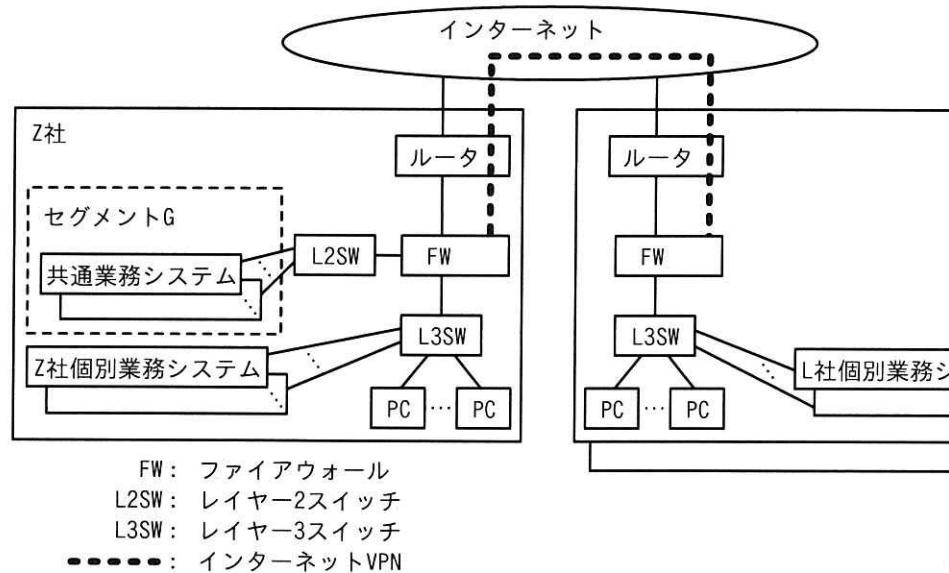


図1 Z社グループのネットワーク構成（抜粋）

〔Z社の現状のセキュリティ対策〕

Z社は、信頼できる領域と信頼できない領域を定め、必要な管理策を策定している。

利用部署在网络边界的防火墙 (FW) 过滤来自互联网的访问, 只允许符合条件的通信进入内部网络, 所以采用的是“境界防御”的思想。

对策2: 安装恶意软件防护软件, 防止恶意软件感染。

对策3: 定期确认漏洞信息, 及时打补丁和更新。

对策4: 上线前进行漏洞诊断, 修复后再投入使用。

供应链攻击!

业务 → 攻击合作伙伴 (子公司、供应商)

服务 → 攻击云服务/IT 服务商

软件 → 攻击软件开发商或开源组件

Z 社の現状のセキュリティ対策は次のとおりである。

対策1: a の考え方にに基づき, インターネットから Z 社の内
クへの攻撃を入口となる FW で防いでいる。具体的には, 子会
ターネット VPN 経由での共通業務システムへのアクセスは許
ーネットから Z 社内へのその他のアクセスは, 共通業務シス
セスも含めて禁止している。

対策2: Z 社内の, PC 及び業務システムが稼働しているサーバにはマ
ソフトを導入している。

対策3: Z 社内の, PC, 業務システムが稼働しているサーバ及びネッ
に対し, 各ベンダーからの脆弱性情報やアップデート情報^{ぜい}を
て, 適宜セキュリティパッチの適用やアップデートを実施して

対策4: Z 社内の業務システムは, 導入時に脆弱性診断を実施してい
発見された場合は, 利用開始までに対応を実施している。

なお, 各子会社については, それぞれ独自にセキュリティ対策を実施

〔サプライチェーン攻撃の調査〕

ある日, Z 社の情報システム部の B 部長は, 同業他社においてサプラ
撃による被害の事例が複数報告されていることを知り, T 主任にサプラ
撃の事例を調査して整理するように指示した。

T 主任が調査した結果, サプライチェーン攻撃には幾つかのパターン
分かった。T 主任が整理したパターンを次に示す。

(1) ビジネスサプライチェーン攻撃

標的とする会社の, セキュリティ対策が不十分な子会社や取引先
社を攻撃して, そこのシステムを踏み台として, 内部ネットワーク
て標的とする会社を攻撃する。

(2) サービスサプライチェーン攻撃

標的とする会社が利用している IT サービスの運営事業者などを攻
サービスのアカウントを乗っ取ったり, そのサービスを経由してマ
布したりすることによって, 最終的に標的とする会社を攻撃する。

(3) ソフトウェアサプライチェーン攻撃

標的とする会社の業務システムなどに導入しているソフトウェアを攻撃してソースコードを改ざんしたり、業務システムなどで利用しているソースのソフトウェアライブラリの脆弱性を利用したりすることによって最終的に標的とする会社を攻撃する。

(1)～(3)のパターンについて、T 主任が B 部長に報告したときの会話

B 部長： サプライチェーン攻撃に対して、Z 社グループの現状のセキュリティ対策は十分ですか。

T 主任： 不十分だと思います。Z 社については、a の考えは、ネットワーク内の機器の防御を行っているので、攻撃者によってネットワークに侵入されてしまうと、内部ネットワーク内の業務システムが容易に攻撃されるおそれがあります。

B 部長： なるほど。実際、幾つかの共通業務システムは、インターネットも含む内部ネットワークからであれば認証無しでアクセス可能なもので、内部ネットワークに侵入された場合に情報漏洩があるということですね。その他の懸念はありますか。

T 主任： 業務システムについても懸念があります。システム導入時に脆弱性診断を実施しておらず、導入以降に明らかになった脆弱性や脆弱性がないおそれがあります。また、Z 社グループ全体に視点を向けてマルウェア対策ソフトの選定やネットワーク機器の設定など、それぞれ独自にセキュリティ対策を実施しているので、セキュリティ対策が不十分な会社が存在するおそれがあります。

B 部長： 分かりました。今後は各社任せにするのではなく、我々 Z 社として Z 社グループ全体のセキュリティ対策を強化していく必要があり、Z 社グループ全体として追加すべきセキュリティ対策を検討します。

〔追加すべきセキュリティ対策〕

T 主任は Z 社グループ各社の現状のセキュリティ対策を調査し、追加すべきセキュリティ対策を検討して次のようにまとめた。なお、子会社に対しては

以前主要防外部攻击，现在还要防“内部人”，即使攻击者进入内网，也不能随意访问系统，因此要加强内部访问控制、定期查漏洞，并统一管理整个集团的安全。

B (Need to Know) : 员工只能访问完成工作所**需要知道 (Need to Know) **的信息和系统, 不授予超出业务需要的访问权限, 从而降低信息泄露风险。

C (デフォルトパスワード) : 题干提到“同一型号设备通常共用的密码”, 因此可判断为默认密码, 应修改为难以猜测的密码。

D (SIEM) : 题干提到“分析日志以发现攻击征兆和尽早发现攻击”, 因此可判断为SIEM, 用于集中收集、关联分析日志, 监测安全事件。

に加えて, ① Z 社グループ全体の統制を強化しサプライチェーン攻撃の害を低減する施策の実施を依頼する。

対策 5: 全ての業務システムへのアクセスに対しては, 従業員ごとに書とパスワードによる認証を行う。また, パスワードは類推されただけが利用できるようにシステムで制限する。加えて, [] に従い, 各従業員に対して過剰な権限を与えないようにする。

対策 6: 機密性の高い内部情報を扱う業務システムへのアクセスに対して多要素認証を行う。

対策 7: ネットワーク機器などの管理用アカウントのパスワードは類推されやすいものにする。特に, 機器の型番ごとに共通であることが多いため, パスワードの利用は禁止する。

対策 8: 業務システム, 業務システムが稼働しているサーバ及びネットワークへのアクセスについては監視及びログの記録を行い, そのログを [] d で分析することによって攻撃の予兆検知や早期発見が可能となる。また, 業務システムやインターネットへのアクセスログが記録されていることを Z 社グループ各社の従業員に周知し, ②データの持出しや不正アクセスの抑止する。

対策 9: 業務システム, 業務システムが稼働しているサーバ及びネットワークについては, 機密情報の取扱いの有無などの重要度に応じて 1 年～3 年の周期で定期的な脆弱性診断を行い, 発見された脆弱性への対策を依頼する。

T 主任が検討の結果を B 部長に報告したところ, ③ソフトウェアサプライチェーン攻撃への対策として“対策 9”に加えて実施すべき内容があると指摘された。

T 主任は, 業務システムなどで使用しているソフトウェア製品及びライブラリについて, 名称, バージョン, 開発会社名などを一覧にまとめた [] e とを, “対策 10”としてセキュリティ対策に追加することにした。

T 主任は“対策 10”も含めて B 部長に改めて報告し, 追加すべきセキュリティ対策が承認された。

①Z社グループ全体の統制を強化し
サプライチェーン攻撃のリスク又
は被害を低減する施策

ア ☒ 开发前审查委托开发公司的
安全措施。属于供应链管理，正
确。

イ ☒ 集团统一制定安全事件报告
和应对流程。加强集团统制，正
确。

エ ☒ 集团统一网络设备配置策
略。统一安全策略，正确。

ウ ☒ (答案) 把各公司的业务系
统放到同一个网络段 (セグメント
G)，但仍由各公司各自管理。

这没有实现题干要求的“由 Z 社统
一加强管理”，反而只是改变了网
络位置，管理方式没有改变，也不
能有效降低供应链攻击风险。

就直接回答 不正を行うと、発覚リスト
があると分かっているから
ばれるなど、也可以

業務システムやインターネットへの
アクセスログが記録されていることを
Z 社グループ各社の従業員に周知し、
②データの持出しなどの内部不正を抑
止する。
就直接回答 不正を行うと、発覚リスト
があると分かっているから
ばれるなど、也可以

設問 1 本文中の , , ,
な字句を、それぞれ解答群の中から選び、記号で答えよ。

解答群

ア	CASB	イ	MDM	ウ	need-to-know	エ	
オ	SBOM	カ	SIEM	キ	SLCP	ク	境界
ケ	サンドボックス	コ	ゼロトラスト	サ	多層		

設問 2 本文中の に入れる適切な字句を、5 字以内で答えよ

設問 3 [追加すべきセキュリティ対策] について答えよ。

(1) 本文中の下線①について、具体的な施策として適切なものを
中から選び、記号で答えよ。

解答群

ア Z 社グループ各社で業務システムを開発する場合、開発

においてセキュリティ対策が十分に実施されているかを委

イ Z 社グループ各社でセキュリティインシデントが発生し

び対応のフローを定める。

ウ Z 社グループ各社の個別業務システムを全てセグメント

システムの詳細を把握している各社の情報システム部が引

エ Z 社グループ各社のネットワーク機器の設定ポリシーを

一する。

(2) 本文中の下線②について、内部不正の抑止につながる理由を
えよ。

(3) 本文中の下線③について、B 部長は何を懸念して指摘したと
脆弱性対策の観点に着目して 35 字以内で答えよ。

T 主任が検討の結果を B 部長に報告したところ、③ソフトウェアサプライチェーン
して“対策 9”に加えて実施すべき内容があると指摘された。そこで T 主任は、業務
使用しているソフトウェア製品及びライブラリについて、名称、バージョン、開発
覧にまとめた e を作成することを、“対策 10”としてセキュリティ対策に追加するこ

这里就是考为什么要做一个 SBOM，就直接背
背一下脆弱性が発見された際に、影響範囲を迅速に判断できないこと